AXSHARE — Master Roadmap di Sviluppo

> Secure File Sharing Platform — End-to-End Encrypted, GDPR & NIS2 Compliant **Path progetto:** `/Users/r.amoroso/Documents/Cursor/AXSHARE` **Data:** 2026-03-04 | **Versione:** 2.0 — Stack FastAPI + PostgreSQL + Next.js

---

Stack Tecnologico Definitivo

Layer	Tecnologia	Note
Backend API	FastAPI 0.115 (Python 3.12) + Uvicorn + Gunicorn	Async nativo, OpenAPI auto-generata
ORM	SQLAlchemy 2.0 async + Alembic	Migrations versionabili
Task Queue	Celery 5 + Redis	Auto-distruzione, report, notifiche async
Database	PostgreSQL 16	RLS, JSONB, full-text search, audit log
Cache / TTL	Redis 7	Permessi a tempo, sessioni, rate limiting
Storage File	MinIO (S3-compatible)	Self-hosted + cloud, zero-knowledge
Cifratura	PyNaCl (libsodium) + cryptography (AES-256-GCM) + X25519	Standard moderni
Key Management	HashiCorp Vault + hvac (Python client)	HSM-ready, GDPR/NIS2
Firma Digitale	pyHanko (PAdES/CAdES eIDAS)	Standard europeo
Auth	py_webauthn + pyotp (TOTP) + python-jose (JWT RS256)	MFA obbligatorio
Frontend Web	Next.js 14 App Router + React + TypeScript	SSR + CSR
UI Components	shadcn/ui + Tailwind CSS	Accessibile, moderno
Client Desktop	Tauri 2 (Rust + WebView2)	Mac + Windows nativo
Disco Virtuale	macFUSE / WinFsp via Tauri plugin	Cifrato, inutilizzabile senza auth
Test Backend	pytest + pytest-asyncio + httpx	Unit + integration
Test Frontend	Vitest + Playwright	Component + E2E

Layer	Tecnologia	Note
Load Test	k6	Performance e stress test
Infra Dev	Docker Compose	Stack locale completo
Infra Cloud	Terraform (AWS/Azure) + GitHub Actions	IaC + CI/CD

Overview Fasi

Fase	Nome	Task	Priorita
FASE 1	Foundation & Infrastruttura	1.1 - 1.5	Critica
FASE 2	Crittografia & Key Management	2.1 - 2.5	Critica
FASE 3	Backend Core — Auth & Utenti	3.1 - 3.5	Critica
FASE 4	File System & Storage E2E	4.1 - 4.5	Critica
FASE 5	Permessi a Tempo & Gruppi	5.1 - 5.4	Alta
FASE 6	Auto-Distruzione	6.1 - 6.3	Alta
FASE 7	Client Desktop Mac/Windows	7.1 - 7.5	Alta
FASE 8	Metadati & Ricerca Avanzata	8.1 - 8.3	Media
FASE 9	Firma Digitale	9.1 - 9.4	Media
FASE 10	Condivisione Esterna & Guest	10.1 - 10.4	Alta
FASE 11	Reportistica & Audit Log	11.1 - 11.3	Media
FASE 12	Compliance GDPR/NIS2 & Deploy	12.1 - 12.4	Critica

Totale: 50 Task — 12 Fasi

FASE 1 — Foundation & Infrastruttura

> Struttura monorepo, ambiente Docker, database, configurazione base servizi

Task	Nome	File Prompt
1.1	Scaffold monorepo (struttura cartelle, Python venv, config base)	TASK-1.1-scaffold-monorepo.md
1.2	Docker Compose stack completo (PostgreSQL, Redis, MinIO, Vault)	TASK-1.2-docker-compose.md
1.3	PostgreSQL — schema base, RLS, Alembic migrations	TASK-1.3-postgresql-schema.md
1.4	MinIO — bucket policy, CORS, configurazione server	TASK-1.4-minio-setup.md
1.5	HashiCorp Vault — secrets engine KV2, policy, hvac client Python	TASK-1.5-vault-setup.md

Test fine fase: tests/phase1/test_infra.py

- Connessione PostgreSQL attiva, schema presente
- Redis PING/PONG
- MinIO bucket raggiungibile e policy corretta
- Vault health check OK, secret engine abilitato

FASE 2 — Crittografia & Key Management

> Libreria crypto Python condivisa, generazione chiavi, key exchange E2E

Task	Nome	File Prompt
2.1	Modulo crypto/aes.py — AES-256-GCM encrypt/decrypt file e metadati	TASK-2.1-crypto-aes.md
2.2	Modulo crypto/rsa.py — RSA-4096 keypair, storage chiave privata cifrata	TASK-2.2-crypto-rsa.md
2.3	Modulo crypto/ecdh.py — X25519 key exchange, shared secret per gruppi	TASK-2.3-crypto-ecdh.md
2.4	Modulo crypto/vault.py — KEK wrap/unwrap chiavi file su Vault	TASK-2.4-key-wrapping.md
2.5	Modulo crypto/kdf.py — Argon2id derivazione chiavi da password	TASK-2.5-key-derivation.md

Test fine fase: tests/phase2/test_crypto.py

- AES-256-GCM: encrypt/decrypt round-trip corretto
- RSA-4096: cifratura con pubkey, decifratura con privkey
- X25519: shared secret identico per entrambe le parti
- Vault: wrap chiave e unwrap restituisce originale
- Argon2id: hash deterministico da stessa password+salt

FASE 3 — Backend Core — Auth & Utenti

> FastAPI app, autenticazione WebAuthn + TOTP, gestione utenti e gruppi

Task	Nome	File Prompt
3.1	FastAPI setup — struttura app, router, middleware CORS/logging, config Pydantic	TASK-3.1-fastapi-setup.md
3.2	Auth WebAuthn — registrazione Passkey, autenticazione, py_webauthn	TASK-3.2-auth-webauthn.md
3.3	Auth TOTP + JWT — pyotp TOTP, JWT RS256 python-jose, refresh token	TASK-3.3-auth-totp-jwt.md
3.4	Users module — CRUD, ruoli (admin/user/guest), profilo, chiavi pubbliche	TASK-3.4-users-module.md
3.5	Groups module — CRUD gruppi, membership, distribuzione chiavi condivise E2E	TASK-3.5-groups-module.md

Test fine fase: tests/phase3/test_auth.py

- Registrazione utente e WebAuthn challenge/response
- Login con TOTP corretto → JWT valido
- Login con TOTP errato → 401
- Creazione gruppo e aggiunta membro
- Endpoint protetto rifiuta richiesta senza JWT

FASE 4 — File System & Storage E2E

> Upload/download cifrato lato client, struttura cartelle, zero-knowledge sul server

Task	Nome	File Prompt
4.1	Upload cifrato — chunked multipart, AES-GCM pre-upload, store MinIO	TASK-4.1-upload-encrypted.md
4.2	Download + decrypt — streaming MinIO, decifratura nel browser/client	TASK-4.2-download-decrypt.md
4.3	Folders — struttura ad albero, nomi cartelle cifrati, path opachi	TASK-4.3-folders-tree.md
4.4	Versioning — snapshot versioni cifrate, diff, rollback	TASK-4.4-file-versioning.md
4.5	Preview client-side — thumbnail e anteprima generate solo nel browser	TASK-4.5-preview-client.md

Test fine fase: tests/phase4/test_storage.py

- Upload file e verifica contenuto cifrato su MinIO (illeggibile senza chiave)
- Download e decrypt: contenuto identico all'originale
- Navigazione cartelle con path opachi
- Rollback a versione precedente funzionante
- Preview visibile solo a utente autenticato con chiave corretta

---

FASE 5 — Permessi a Tempo & Gruppi

> ACL granulare, scadenze TTL automatiche via Redis, revoca istantanea

Task	Nome	File Prompt
5.1	Permissions ACL — granulare per file/cartella (read/write/share/admin)	TASK-5.1-permissions-acl.md
5.2	Time-based permissions — TTL Redis, scadenza automatica, notifica pre-scadenza	TASK-5.2-permissions-ttl.md
5.3	Group permissions — propagazione permessi a gruppo con stesse chiavi E2E	TASK-5.3-group-permissions.md
5.4	Permission audit — log ogni accesso/modifica permessi con IP, timestamp, user-agent	TASK-5.4-permission-audit.md

Test fine fase: tests/phase5/test_permissions.py

- Accesso consentito con permesso valido
- Accesso negato dopo scadenza TTL Redis
- Propagazione permesso a tutti i membri del gruppo
- Log audit creato per ogni evento di accesso

FASE 6 — Auto-Distruzione

> Eliminazione definitiva e irrecuperabile di file, cartelle e chiavi crittografiche

Task	Nome	File Prompt
6.1	Self-destruct trigger — manuale immediato e schedulato (data/ora) via Celery beat	TASK-6.1-self-destruct-trigger.md
6.2	Secure delete — sovrascrittura binaria MinIO + wipe PostgreSQL + shred chiavi Vault	TASK-6.2-secure-delete.md
6.3	Condizioni distruzione — dopo N accessi, N download, prima apertura link esterno	TASK-6.3-self-destruct-conditions.md

Test fine fase: tests/phase6/test_destruct.py

- File non recuperabile dopo trigger (404 su MinIO, NULL su DB)
- Chiavi eliminate da Vault e non ripristinabili
- Log certificato distruzione con hash pre-delete
- Trigger condizionale funzionante (es. dopo 3 download)

FASE 7 — Client Desktop Mac/Windows

> App Tauri con disco virtuale cifrato, sync automatica, protezione file locali

Task	Nome	File Prompt
7.1	Tauri 2 setup — struttura Rust + WebView, build pipeline Mac (dmg) + Win (msi)	TASK-7.1-tauri-setup.md
7.2	Login desktop — WebAuthn nativo + scambio chiavi con API, keychain OS	TASK-7.2-desktop-auth.md
7.3	Disco virtuale cifrato — mount macFUSE/WinFsp, visibile solo con app autenticata	TASK-7.3-virtual-disk.md
7.4	Sync engine — bidirezionale cifrata, delta sync, conflict resolution	TASK-7.4-sync-engine.md
7.5	Export protection — file copiati fuori dal disco virtuale risultano corrotti	TASK-7.5-export-protection.md

Test fine fase: tests/phase7/test_desktop.py

- Mount disco virtuale e listing file decifrati
- File accessibile con auth, inaccessibile senza
- File copiato sul desktop = header mancante, illeggibile

- Sync upload e download con server verificato
- Conflict resolution su modifica contemporanea

FASE 8 — Metadati & Ricerca Avanzata

> Schema metadati cifrati lato client, classificazione dati, ricerca zero-knowledge

Task	Nome	File Prompt
8.1	Metadata — schema JSONB cifrato per file/cartella (tag, custom fields, date, autore)	TASK-8.1-metadata-schema.md
8.2	Search — indice cifrato client-side, ricerca su token HMAC (blind search)	TASK-8.2-search-encrypted.md
8.3	Classification — livelli sensibilita dati (PUBLIC/INTERNAL/CONFIDENTIAL/SECRET)	TASK-8.3-classification.md

Test fine fase: tests/phase8/test_metadata.py

- Salvataggio metadati cifrati e recupero/decifratura corretta
- Ricerca per tag restituisce risultati attesi
- Metadati sul server non leggibili in chiaro
- Classificazione applicata e policy rispettata

FASE 9 — Firma Digitale

> Firma PAdES/CAdES su file singolo, multi-file e cartella con verifica chain of trust

Task	Nome	File Prompt
9.1	Firma singolo file — PAdES (PDF) e CAdES (generico) con pyHanko + chiave utente	TASK-9.1-sign-single.md
9.2	Multi-file signature — firma batch + manifest XML firmato	TASK-9.2-sign-multi.md
9.3	Folder signature — firma ricorsiva cartella + Merkle tree hash	TASK-9.3-sign-folder.md
9.4	Verifica firma — chain of trust, timestamp RFC 3161, integrità file	TASK-9.4-verify-signature.md

Test fine fase: tests/phase9/test_signature.py

- Firma valida su PDF e file generico
- Verifica positiva su file integro
- Verifica negativa su file manomesso (byte alterato)
- Merkle tree cartella: aggiunta file invalida firma
- Timestamp verificabile da terza parte

FASE 10 — Condivisione Esterna & Guest

> Invito utenti esterni con chiavi E2E, zero accesso senza autorizzazione esplicita

Task	Nome	File Prompt
10.1	External share — link cifrato con chiave sessione usa-e-getta + TTL	TASK-10.1-external-share.md
10.2	Guest user — registrazione solo su invito, proprie chiavi E2E, profilo limitato	TASK-10.2-guest-creation.md
10.3	Approval flow — owner approva ogni accesso esterno prima attivazione	TASK-10.3-share-approval.md
10.4	Revoca condivisione — istantanea, elimina chiavi sessione, invalida link	TASK-10.4-share-revocation.md

Test fine fase: tests/phase10/test_sharing.py

- Link non funzionante prima di approvazione owner
- Guest accede solo dopo approvazione esplicita
- Accesso guest con chiavi valide: file visibile e decifrabile
- Revoca: link invalido entro 1 secondo
- Utente non invitato: 403, nessuna informazione esposta

FASE 11 — Reportistica & Audit Log

> Log accessi immutabile, dashboard permessi, export report conformita

Task	Nome	File Prompt
11.1	Audit log — ogni azione tracciata, append-only, hash chain per immutabilita	TASK-11.1-audit-log.md
11.2	Permissions dashboard — UI Next.js per admin: vista permessi per utente/gruppo/file	TASK-11.2-permissions-dashboard.md
11.3	Report engine — export PDF/CSV audit trail, report periodici schedulati con Celery	TASK-11.3-report-engine.md

Test fine fase: tests/phase11/test_audit.py

- Log generato per ogni azione sensibile (upload, download, share, delete, firma)
- Tentativo modifica log fallisce (hash chain rotto)
- Export PDF audit trail completo e leggibile
- Dashboard mostra dati corretti per admin, nascosti per user

---

FASE 12 — Compliance GDPR/NIS2 & Deploy

> Conformita normativa, hardening sicurezza, deploy ibrido cloud + on-prem

Task	Nome	File Prompt
12.1	GDPR — right to erasure completo, data portability export, consent tracking	TASK-12.1-gdpr-module.md
12.2	NIS2 hardening — TLS 1.3 enforced, rate limiting, IP allowlist, anomaly detection	TASK-12.2-nis2-hardening.md
12.3	Deploy on-prem — Docker Compose produzione, backup automatico, restore verificato	TASK-12.3-deploy-onprem.md
12.4	Deploy cloud — Terraform AWS/Azure, autoscaling, CDN CloudFront/Azure CDN, DR	TASK-12.4-deploy-cloud.md

Test fine fase: tests/phase12/test_compliance.py

- Right to erasure: zero dati utente rimasti dopo richiesta
- TLS 1.3 enforced, TLS 1.2 e inferiori bloccati
- Rate limiting: 429 dopo soglia su endpoint critici
- Backup eseguito, restore funzionante e verificato
- Deploy cloud: health check OK, autoscaling attivo

Mappa completa file prompt da generare (51 file)

```
AXSHARE/
├── AXSHARE_ROADMAP.md
├── TASK-1.1-scaffold-monorepo.md
├── TASK-1.2-docker-compose.md
├── TASK-1.3-postgresql-schema.md
├── TASK-1.4-minio-setup.md
├── TASK-1.5-vault-setup.md
├── TASK-2.1-crypto-aes.md
├── TASK-2.2-crypto-rsa.md
├── TASK-2.3-crypto-ecdh.md
├── TASK-2.4-key-wrapping.md
├── TASK-2.5-key-derivation.md
├── TASK-3.1-fastapi-setup.md
├── TASK-3.2-auth-webauthn.md
├── TASK-3.3-auth-totp-jwt.md
├── TASK-3.4-users-module.md
├── TASK-3.5-groups-module.md
├── TASK-4.1-upload-encrypted.md
├── TASK-4.2-download-decrypt.md
├── TASK-4.3-folders-tree.md
├── TASK-4.4-file-versioning.md
├── TASK-4.5-preview-client.md
├── TASK-5.1-permissions-acl.md
├── TASK-5.2-permissions-ttl.md
├── TASK-5.3-group-permissions.md
├── TASK-5.4-permission-audit.md
├── TASK-6.1-self-destruct-trigger.md
├── TASK-6.2-secure-delete.md
├── TASK-6.3-self-destruct-conditions.md
├── TASK-7.1-tauri-setup.md
├── TASK-7.2-desktop-auth.md
├── TASK-7.3-virtual-disk.md
├── TASK-7.4-sync-engine.md
├── TASK-7.5-export-protection.md
├── TASK-8.1-metadata-schema.md
├── TASK-8.2-search-encrypted.md
├── TASK-8.3-classification.md
├── TASK-9.1-sign-single.md
├── TASK-9.2-sign-multi.md
├── TASK-9.3-sign-folder.md
├── TASK-9.4-verify-signature.md
```

```
├── TASK-10.1-external-share.md
├── TASK-10.2-guest-creation.md
├── TASK-10.3-share-approval.md
├── TASK-10.4-share-revocation.md
├── TASK-11.1-audit-log.md
├── TASK-11.2-permissions-dashboard.md
├── TASK-11.3-report-engine.md
├── TASK-12.1-gdpr-module.md
├── TASK-12.2-nis2-hardening.md
├── TASK-12.3-deploy-onprem.md
└── TASK-12.4-deploy-cloud.md
```

Regole operative per Cursor

1. **Rispettare la sequenza fasi** — le fasi hanno dipendenze (Fase 2 richiesta da Fase 4, etc.)
2. **Ogni task genera il proprio `.md`** nella root con risultati, comandi eseguiti e output test
3. **Test automatici** a fine ogni fase: `pytest tests/phaseN/ -v` con output salvato nel MD di fase
4. **Mai hardcodare segreti** — sempre da `.env` o Vault, mai in codice sorgente
5. **Principio zero-knowledge assoluto** — il server non riceve file in chiaro ne chiavi private, mai
6. **Ogni modifica DB** passa attraverso una migration Alembic versionata e reversibile
7. **Ogni modulo backend** ha il proprio router FastAPI, schema Pydantic e service layer separati